

Préparation à la certification CEH

Dr N'GORAN K. Rodrigue
Ingénieur Docteur en Informatique option Cybersécurité

ESATIC

Mar. 2026

Sommaire

1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
3. Attaques sur les applications web
4. Ingénierie sociale et phishing
5. Post-Exploitation
6. Rédaction du rapport de test d'intrusion

1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
3. Attaques sur les applications web
4. Ingénierie sociale et phishing
5. Post-Exploitation
6. Rédaction du rapport de test d'intrusion

Ethical hacking ou hacking éthique

- ▶ Méthodes de découverte et d'exploitation **de vulnérabilités** (tests d'intrusion...) **de façon légale avec l'autorisation des propriétaires** d'un système dans le but de l'améliorer
- ▶ Sécuriser un système sans en tirer **un profit de manière illicite**
- ▶ Comprendre les stratégies **malveillantes** et **s'en défendre**

Identification et évaluation des vulnérabilités

- ▶ **Techniques d'analyse** : Analyse approfondie des protocoles réseau, configuration système, applications web, etc. Combinaison d'observations passives et de tests actifs à travers des tests d'intrusion(pentesting).
- ▶ **Rapport et recommandations** : Élaboration d'un rapport exhaustif et de qualité qui expose chaque faille détectée. Ce rapport comporte des recommandations de corrections des vulnérabilités (modification de code, mises à jour de logiciels, etc).
Étape importante qui distingue le hacker éthique du hacker malveillant

Mise en œuvre de mesures de sécurité

Le hacker éthique recommande et accompagne la mise en œuvre des mesures de sécurité à travers :

- ▶ **La collaboration avec les équipes** : de développement, d'administration système, de sécurité, etc.
- ▶ **La formation et sensibilisation** : du personnel (utilisateurs) aux bonnes pratiques de sécurité informatique (ateliers, séminaires de formations).

Le rôle d'un hacker éthique est à la fois **préventif et éducatif**

Informations personnelles et données sensibles

Les lois sur la protection des données, comme **la loi n 2013-450 du 19 juin 2013 en Côte d'Ivoire et le RGPD (Règlement Général sur la Protection des Données) (entrée en vigueur le 25 mai 2018 dans l'Union européenne)** imposent aux organisations :

- ▶ Des contrôles sur la manière dont les données personnelles doivent être collectées (minimisation), traitées et stockées (durée limitée)
- ▶ De s'assurer que les données sont protégées contre l'accès non autorisé et le vol
- ▶ De disposer du consentement des utilisateurs

Informations personnelles et données sensibles

- Possibilité de se conformer à des normes spécifiques comme la norme ISO/IEC 27001 (définit les exigences d'un SMSI (système de gestion de la sécurité des systèmes d'informations))

Section 1: Introduction au Hacking Éthique

9

Les différentes catégories de hackers

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Ingénierie sociale et phishing



Section 1: Introduction au Hacking Éthique

9

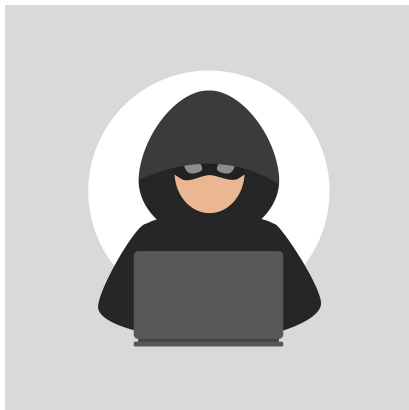
Les différentes catégories de hackers

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Ingénierie sociale et phishing



Qu'est-ce qu'un Hacker ?

- ▶ Origine : **To Hack**
- ▶ **Découper** un objet à l'aide d'un outil
- ▶ Découper des informations **en blocs logiques** et les réassembler
- ▶ **Modifier le fonctionnement** d'un système pour **l'améliorer**
- ▶ **Détourner un système** de son but premier (la protection)
- ▶ Deux choix : **malveillant** ou **bienveillant**

Hacker white hat

- ▶ Agis dans la : **légalité**
- ▶ Recherche à se **protéger** ou à **protéger d'autres systèmes**
- ▶ L'objectif de la **certification CEH** est de devenir un **white hat hacker** !

Hacker black hat

- ▶ Agis dans un but : **personnel** et de façon illégale
- ▶ Vol, altération de données, motivés par un gain financier ou nuire à autrui
- ▶ À l'origine de **virus, chevaux de Troie, logiciels espions**

Hacker grey hat

- ▶ Intention : **mitigée (ni Black, ni White)**
- ▶ Recherche de failles sans autorisation et alerte de façon **illégale ou contre rémunération**

Hackers red hat

- ▶ Se présentent comme : **des justiciers** du cyberspace
- ▶ Ils traquent **activement** les black hat et les neutralisent
- ▶ Leur approche offensive, bien que motivée par la lutte contre la cybercriminalité, s'éloigne du cadre légal et peut générer des dommages collatéraux.

Hacktivistes

- ▶ Combinent : **activisme et hacking**
- ▶ Défendent des **causes politiques, sociales ou idéologiques**
- ▶ Ils ciblent des **entreprises, gouvernements ou organisations qu'ils jugent contraires à leurs valeurs**

Script kiddies

- ▶ **Novices** qui utilisent des scripts sans en comprendre réellement le fonctionnement
- ▶ **Motivation principale** : Curiosité, la reconnaissance ou distraction.
- ▶ Peuvent causer **des dégâts réels** sur des cibles vulnérables

Hackers étatiques (state-sponsored hackers)

- ▶ Opèrent pour le compte **d'un gouvernement**
- ▶ **Missions** : espionnage industriel, déstabilisation politique, collecte de renseignements militaires
- ▶ Disposent de **ressources considérables et de moyens techniques sophistiqués**
- ▶ Représentent une **menace majeure** car leurs opérations sont **planifiées, ciblées et difficiles à attribuer publiquement**

Insiders (acteurs internes)

- ▶ Il peut s'agir **d'employés, de sous-traitants ou de prestataires** disposant d'un **accès légitime** aux systèmes, mais qui **abusent de ces privilèges**
- ▶ **Motivations** : vengeance, idéologie, appât du gain, simple négligence, etc.
- ▶ Sont **redoutables**, exploitent **la confiance accordée**, **échappent parfois** aux contrôles de sécurité classiques

Insiders (acteurs internes)

- ▶ Il peut s'agir **d'employés, de sous-traitants ou de prestataires** disposant d'un **accès légitime** aux systèmes, mais qui **abusent de ces privilèges**
- ▶ **Motivations** : vengeance, idéologie, appât du gain, simple négligence, etc.
- ▶ Sont **redoutables**, exploitent **la confiance accordée**, **échappent parfois** aux contrôles de sécurité classiques

- ▶ **Responsable de la sécurité des systèmes d'information (RSSI)** : définit et met en œuvre la politique de sécurité informatique de l'entreprise
- ▶ **Auditeur en sécurité de système d'information (SSI)** : évalue le niveau de sécurité d'une organisation à travers des scénarios réalistes
- ▶ **Consultant en sécurité offensive** : expert technique avec une capacité à accompagner les clients sur leurs choix stratégiques
- ▶ Participant à des programmes de **bug bounty**, membre d'une Red Team, etc.

Section 2: Présentation de la certification CEH 20

Sommaire

Introduction au Hacking Éthique **Présentation de la certification CEH** Attaques sur les applications web Ingénierie sociale et phishing

1. Introduction au Hacking Éthique
- 2. Présentation de la certification CEH**
3. Attaques sur les applications web
4. Ingénierie sociale et phishing
5. Post-Exploitation
6. Rédaction du rapport de test d'intrusion

Section 2: Présentation de la certification CEH 21

Objectifs, évolution et reconnaissance

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

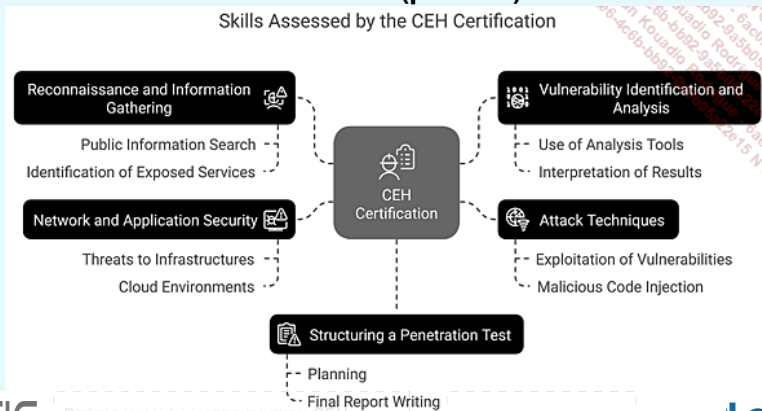
- ▶ La certification **CEH (Certified Ethical Hacker)** a été lancée en 2003 par l'EC-Council (International Council of E-Commerce Consultants)
- ▶ **Objectif** : former des professionnels capables de **penser comme des attaquants** pour mieux défendre les systèmes d'information
- ▶ CEH est **reconnue mondialement** et **souvent exigée dans les offres d'emploi** (pentester, consultant sécurité, etc.)
- ▶ Constitue une base solide pour des certifications comme **l'OSCP (Offensive Security Certified Professional)**, ou le **CISSP (Certified Information Systems Security Professional)**, ou **CISM (Certified Information Security Manager)**.

Section 2: Présentation de la certification CEH 22

Compétences évaluées

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

La certification CEH évalue un large éventail de compétences techniques, organisées autour des **différentes phases d'un test d'intrusion (pentest)**.



Section 2: Présentation de la certification CEH 23

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Ingénierie sociale et phishing

Versions de la CEH

- ▶ **CEH** : Examen Théorique (version standard)
- ▶ **CEH Practical** : Examen pratique dans environnement virtuel et consistant à exploiter des scénarios réels d'attaque et de défense afin de démontrer les compétences techniques du candidat.
- ▶ **CEH Master** : combinaison CEH et CEH Practical (très valorisé) .

Section 2: Présentation de la certification CEH 24

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Ingénierie sociale et phishing

Composition de l'examen CEH

Exam Details	
Characteristic	Detail
 Questions	125
 Duration	4 hours
 Format	MCQ
 Required Score	70%
 Topics	Web, networks, IoT, etc.
 Modalities	Online/Pearson VUE

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières
- ▶ Une Révision régulière des notions est essentielle (pas **simplement de mémoriser** mais de **comprendre comment appliquer les concepts** dans des situations proches du réel.

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières
- ▶ Une Révision régulière des notions est essentielle (pas **simplement de mémoriser** mais de **comprendre comment appliquer les concepts** dans des situations proches du réel.
- ▶ Même si l'examen est théorique, **la pratique** reste un levier fondamental

Section 2: Présentation de la certification CEH 25

Structure et format de l'examen

Introduction au Hacking Éthique

Présentation de la certification CEH

Attaques sur les applications web

Ingénierie sociale et phishing

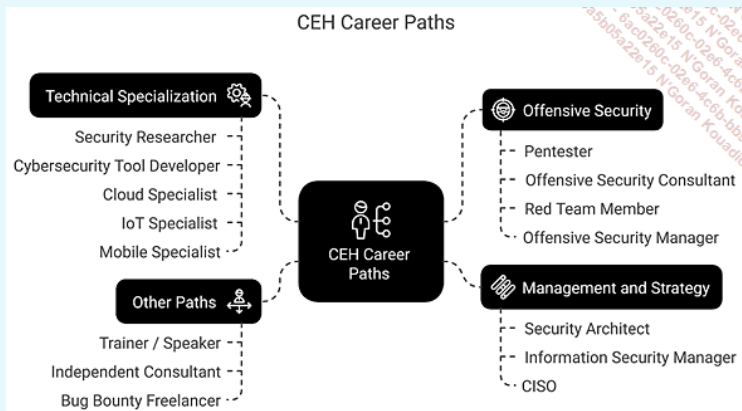
Conseils utiles

- ▶ Les questions couvrent des **éléments théoriques** (définitions, concepts, méthodes) et **des cas pratiques** (scénarios, interprétation d'outils, choix de la meilleure action).
- ▶ **La gestion du temps et du stress est cruciale** : répondre d'abord aux questions les plus familières
- ▶ Une Révision régulière des notions est essentielle (pas **simplement de mémoriser** mais de **comprendre comment appliquer les concepts** dans des situations proches du réel.
- ▶ Même si l'examen est théorique, **la pratique** reste un levier fondamental
- ▶ Faire **des examens blancs** pour se familiariser avec le format

Section 2: Présentation de la certification CEH 26

Avantages professionnels et opportunités de carrière

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing



1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
- 3. Attaques sur les applications web**
4. Ingénierie sociale et phishing
5. Post-Exploitation
6. Rédaction du rapport de test d'intrusion

- ▶ En 2024, 94 % des applications testées présentaient une vulnérabilité (OWASP) (20 % des applications touchées par des injections).
- ▶ 60 % des PME victimes d'une cyberattaque cessent leurs activités dans les six mois qui suivent (Cybersecurity Ventures).
- ▶ La sécurité web repose sur les principes fondamentaux de la sécurité en occurrence **la confidentialité, l'intégrité et la disponibilité**.
- ▶ Requiert une **approche globale de la sécurité** à travers des mesures **techniques, organisationnelles et humaines** (bonnes pratiques de développement (security by design), tests de sécurité réguliers (pentest), formation et sensibilisation des développeurs, des administrateurs et utilisateurs.

OWASP (Open Web Application Security Project)

- ▶ Une organisation mondiale à but non lucratif fondée en 2001 qui est dédiée à **l'amélioration de la sécurité des logiciels**
- ▶ Fournit des **ressources** (guides, des outils et des documentations) et dispose **d'une communauté** composée de professionnels de la sécurité, de développeurs, de chercheurs et d'organisations collaborant ensemble pour partager des connaissances et de meilleures pratiques.
- ▶ **OWASP Top 10** : un projet de l'OWASP qui répertorie les dix vulnérabilités les plus critiques affectant les applications web (liste est mise à jour régulièrement)

OWASP Top 10 :2025

1. A01 :2025 – Contrôle d'accès défaillant (Broken Access Control)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)
5. **A05 :2025** – Injection (Injection)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)
5. **A05 :2025** – Injection (Injection)
6. **A06 :2025** – Conception non sécurisée (Insecure Design)

OWASP Top 10 :2025

1. **A01 :2025** – Contrôle d'accès défaillant (Broken Access Control)
2. **A02 :2025** – Mauvaise configuration de sécurité (Security Misconfiguration)
3. **A03 :2025** – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures)
4. **A04 :2025** – Défaillances cryptographiques (Cryptographic Failures)
5. **A05 :2025** – Injection (Injection)
6. **A06 :2025** – Conception non sécurisée (Insecure Design)
7. **A07 :2025** – Défaillances d'authentification (Authentication Failures)

OWASP Top 10 :2025

- 1.
2. **A08 :2025** –Défaillances d'intégrité des logiciels et des données (Software or Data Integrity Failures)

OWASP Top 10 :2025

- 1.
2. **A08 :2025** –Défaillances d'intégrité des logiciels et des données (Software or Data Integrity Failures)
3. **A09 :2025** – Défaillances de journalisation et d'alerte (Security Logging & Alerting Failures)

OWASP Top 10 :2025

- 1.
2. **A08 :2025** –Défaillances d'intégrité des logiciels et des données (Software or Data Integrity Failures)
3. **A09 :2025** – Défaillances de journalisation et d'alerte (Security Logging & Alerting Failures)
4. **A010 :2025** – Mauvaise gestion des conditions exceptionnelles (Mishandling of Exceptional Conditions)

A01 :2025 – Contrôle d'accès défaillant (Broken Access Control) (+ A10 :2021 - server-side request forgery (ssrf))

- ▶ **Contrôle d'accès** : s'assurer que les utilisateurs authentifiés ne peuvent **accéder qu'aux ressources pour lesquelles ils ont les accès appropriés**
- ▶ **Contrôle d'accès défaillant** : Les restrictions ne sont pas correctement appliquées.
- ▶ **La méthodologie de l'attaque**
 - Modification des URL ou des identifiants pour accéder à des données non autorisées
 - Escalade de privilèges, où un utilisateur standard obtient des droits administratifs
 - Accès à des API non sécurisées permettant des opérations non autorisées

A01 :2025 – Contrôle d'accès défaillant (Broken Access Control)(+ A10 :2021 - server-side request forgery (ssrf))

► Impact

- Accès non autorisé aux données sensibles
- Modification/destruction de données, donc une perte d'intégrité
- Compromission du système (contrôle partiel ou total de l'application par un attaquant)

► Exemple

- Un site e-commerce permet aux utilisateurs d'accéder à leurs commandes via une URL du type :
<https://www.ecomcsia.com/commande?id=123456>
- Si l'application ne vérifie pas que l'utilisateur est autorisé à consulter la commande avec l'ID 123456, alors un attaquant authentifié peut modifier l'ID pour accéder aux commandes d'autres clients :
<https://www.ecomcsia.com/commande?id=987654>

A02 :2025 – Mauvaise configuration de sécurité (Security Misconfiguration) (A05 :2021)

- ▶ une erreur ou un oubli dans la configuration d'un serveur, de frameworks, de bibliothèques ou de bases de données qui exposent l'application à des risques.
- ▶ **Causes courantes**
 - un serveur avec des paramètres par défaut (mots de passe fabricant, ports ouverts, etc.)
 - messages d'erreur trop détaillés qui montrent des informations sensibles ;
 - patches ou mises à jour de sécurité non appliqués ou mal appliqués.

A02 :2025 – Mauvaise configuration de sécurité (Security Misconfiguration) (A05 :2021)

► Impact

- **Exposition des données sensibles** : fichiers de configuration accessibles, énumération de répertoires
- **Prise de contrôle du serveur** : exploitation de failles connues non corrigées
- **Attaque horizontale** : utilisation du serveur compromis pour attaquer d'autres parties du réseau

► Exemple

- Un serveur web Apache avec des configurations par défaut (activation de l'annuaire (structure dossiers, affichage de fichiers)).
- l'identifiant et le mot de passe d'un firewall sont ceux par défaut (admin/admin)

A03 :2025 – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures) (**Nouveau basé sur A06 :2021 - vulnerable and outdated components (composants vulnérables et obsolètes) et A08 :2021 - software and data integrity failures (défaillances d'intégrité des logiciels et des données)**)

- Utilisation de composants externes (bibliothèques, frameworks, modules, outils (CI/CD), etc.) vulnérables dans le développement ou le déploiement d'un logiciel.
- **Causes courantes**
 - Versions obsolètes de bibliothèques avec des failles de sécurité ou provenant de sources non fiables
 - Absence de gestion des dépendances et des mises à jour

A03 :2025 – Défaillances de la chaîne d'approvisionnement logicielle (Software Supply Chain Failures) (Nouveau basé sur A06 :2021 - vulnerable and outdated components (composants vulnérables et obsolètes) et A08 :2021 - software and data integrity failures (défaillances d'intégrité des logiciels et des données))

► Impact

- Compromission de l'application (fonctionnalités réduites ou supprimées)
- Propagation des attaques si les composants sont utilisés dans plusieurs applications, etc.

► Exemple

- En 2021, exploitation d'une vulnérabilité dans la bibliothèque Java Apache Log4j (journalisation) pour compromettre de nombreuses applications dans le monde..

A04 :2025 – Défaillances cryptographiques (Cryptographic Failures) (A02 :2021)

- ▶ Manque de chiffrement ou utilisation de méthodes cryptographiques trop faibles.
- ▶ **Causes courantes**
 - Transmission de données sensibles en clair (sans HTTPS)
 - Utilisation d'algorithmes de chiffrement obsolètes et/ou vulnérables (comme MD5 ou SHA-1)
 - Mauvaise gestion des clés cryptographiques (stockage non sécurisé ou clés facilement prédictibles)

A04 :2025 – Défaillances cryptographiques (Cryptographic Failures) (A02 :2021)

► Impact

- Interception et vol de données sensibles lors de leur transmission ou de leur stockage
- Usurpation d'identité
- Non-conformité réglementaire qui peut entraîner des sanctions légales et financières.

► Exemple

- Une application de messagerie envoie les identifiants des utilisateurs en clair et sans chiffrement. Un attaquant sur le même réseau (par exemple sur un Wi-Fi public) peut intercepter ces informations avec un outil de capture de paquets et accéder ainsi aux comptes des utilisateurs.

A05 :2025 –Injection (Injection) (A03 :2021)

- ▶ Envoie de données non fiables à un interpréteur dans le cadre d'une commande ou d'une requête (injections SQL, LDAP, etc.)
- ▶ **Mode opératoire**
 - Inclusion directe des données de l'utilisateur dans des requêtes sans validation ;
 - Utilisation de chaînes de requêtes construites dynamiquement à partir d'entrées utilisateur.

A05 :2025 –Injection (Injection) (A03 :2021)

► Impact

- accès non autorisé aux données : lecture, modification ou suppression de données dans la base ;
- compromission du serveur
- perte d'intégrité et de disponibilité

A05 :2025 –Injection (Injection) (A03 :2021)

► Exemple

- Un formulaire de connexion tout simple requiert un nom d'utilisateur et un mot de passe, puis exécute la requête SQL suivante sans validation :

```
SELECT * FROM utilisateurs WHERE nom = 'nom_utilisateur' AND mdp = 'mot_de_passe';
```

Si un attaquant écrit ' OR '1'='1' comme nom d'utilisateur et laisse le mot de passe vide, la requête deviendrait alors :

```
SELECT * FROM utilisateurs WHERE nom = " OR '1'='1' AND mdp = " ;
```

Cela peut permettre à l'attaquant de contourner l'authentification .

A06 :2025 – Conception non sécurisée (Insecure Design)(A04 :2021)

- ▶ Absence de contrôles de sécurité dès la phase de conception de l'application (phase de développement)
- ▶ **Causes courantes**
 - Absence de validation des entrées utilisateur ;
 - Développement d'applications qui ne considèrent pas les scénarios d'abus et/ou d'attaques
 - Manque de séparation des privilèges ou de contrôle d'accès granulaire

A06 :2025 – Conception non sécurisée (Insecure Design)(A04 :2021)

► Impact

- Vulnérabilités dès le départ, difficiles à corriger ultérieurement, qui seront plus ou moins facilement trouvées par des cybercriminels ;
- Coûts de remédiation élevés, nécessitant parfois une refonte complète de l'application.

► Exemple

- Une application de transfert d'argent ne prévoit pas de limite sur le montant pouvant être transféré par transaction. Un attaquant peut exploiter cette absence de contrôle pour effectuer des transferts massifs non autorisés.

A07 :2025 – Défaillances d'authentification (Authentication Failures) (Renommé A07 :2021 identification and authentication failures (échecs d'identification et d'authentification))

- ▶ Mauvaise gestion de l'identification des utilisateurs
- ▶ **Causes courantes**
 - Mots de passe faibles ou pas assez complexes ;
 - Absence de protection contre les attaques par force brute ;
 - Sessions non désactivées après la déconnexion de l'utilisateur.

A07 :2025 – Défaillances d'authentification (Authentication Failures) (Renommé A07 :2021 identification and authentication failures (échecs d'identification et d'authentification))

► Impact

- Usurpation d'identité : accès non autorisé aux comptes utilisateur ;
- Atteinte à la confidentialité : accès aux informations personnelles et sensibles ;
- Escalade de privilèges : accès à un compte administrateur.

► Exemple

- Un site web qui n'impose pas de limite sur le nombre de tentatives de connexion. Un attaquant utilise alors un script pour essayer des milliers de combinaisons de mots de passe jusqu'à trouver le bon.

A08 :2021 - software and data integrity failures (défaillances d'intégrité des logiciels et des données) (A08 :2021)

- ▶ Absence de vérification de la fiabilité des plug-ins, mises à jour non signées, etc.
- ▶ **Causes courantes**
 - Téléchargement de mises à jour ou de packages sans vérification de leur intégrité ;
 - Utilisation de bibliothèques et/ou de dépendances provenant de sources non fiables ;
 - Absence de contrôle sur les données critiques utilisées par l'application.

A08 :2021 - software and data integrity failures (défaillances d'intégrité des logiciels et des données) (A08 :2021)

► Impact

- Infection par des logiciels malveillants et ou injection de code malveillant dans l'application
- Fonctionnalités réduites ou supprimées : comportements inattendus ou dangereux

► Exemple

- Une application télécharge automatiquement des mises à jour depuis un serveur sans vérifier la signature numérique. Un attaquant réussit à rediriger le téléchargement vers un package malveillant qu'il a lui-même créé, ce qui infecte ainsi tous les utilisateurs de l'application.

A09 :2025 – Défaillances de journalisation et d'alerte (Security Logging & Alerting Failures)) (A09 :2021)

- ▶ L'absence ou l'insuffisance de journalisation (logs) et de surveillance (monitoring) empêche la détection des attaques en cours ou des tentatives d'exploitation.
- ▶ **Causes courantes**
 - Logs insuffisants ou inexistantes sur les événements de sécurité
 - Absence d'alertes en cas d'activités suspectes
 - Journaux non protégés ou stockés de manière non sécurisée.

A09 :2025 – Défaillances de journalisation et d'alerte (Security Logging & Alerting Failures)) (A09 :2021)

► Impact

- détection tardives des attaques
- enquêtes difficiles : manque d'informations pour analyser l'incident et identifier l'origine (forensic) ;
- non-conformité réglementaire : des normes exigent une journalisation adéquate, ce qui peut amener à des amendes.

► Exemple

- Après une violation de données, une entreprise réalise qu'elle n'a pas de logs pour retracer les actions de l'attaquant, rendant impossible l'évaluation complète de l'impact. Ils se retrouvent donc dans une impasse pour justifier l'attaque et pour essayer de s'améliorer.

A010 :2025 – Mauvaise gestion des conditions exceptionnelles (Mishandling of Exceptional Conditions) (**Nouveau**)

- ▶ Mauvaise gestion des exceptions (contrôle, sécurisation) du aux conditions anormales que peuvent rencontrer les systèmes (la gestion inadéquate des erreurs, les erreurs logiques, les erreurs d'ouverture inopinée, etc)
- ▶ **Causes courantes**
 - logs insuffisants ou inexistants sur les événements de sécurité ;
 - Mauvaise gestion du code (Exceptions ignorées ou mal traitées, Retour d'erreurs non contrôlé)
 - Manque de validation des entrées, Données inattendues non filtrées
 - Fichiers ou connexions non fermés, Timeout non géré
 - Mode debug actif en production

A010 :2025 – Mauvaise gestion des conditions exceptionnelles (Mishandling of Exceptional Conditions) (Nouveau)

► Impact

- Divulgarion d'informations sensibles
- Facilitation des attaques (injection SQL, XSS, etc) reconnaissance système
- Déni de service (DoS), crash de l'application

► Exemple

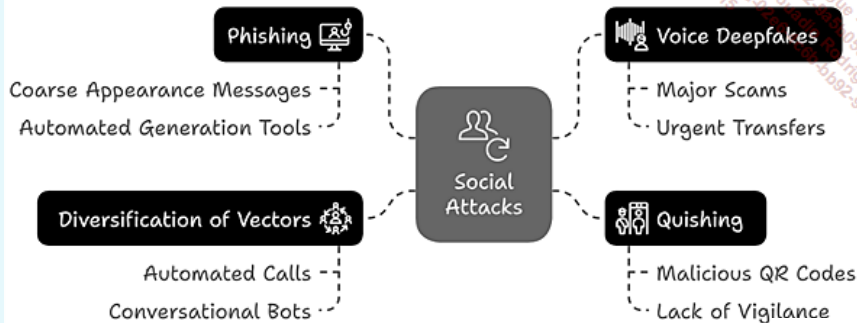
Divulgarion de données sensibles suite à une mauvaise gestion ou à des erreurs de base de données révélant l'intégralité du dysfonctionnement du système à l'utilisateur. L'attaquant continue de provoquer des erreurs afin d'exploiter ces informations sensibles pour mener une attaque par injection SQL plus efficace. Les données sensibles contenues dans les messages d'erreur utilisateur servent à la reconnaissance.

1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
3. Attaques sur les applications web
- 4. Ingénierie sociale et phishing**
5. Post-Exploitation
6. Rédaction du rapport de test d'intrusion

- ▶ **Une surface d'attaque trop souvent négligée**
 - Priorité aux vulnérabilités techniques (ports, configuration, etc.)
 - **humain** : la faille exploitable la plus accessible et la plus fiable
- ▶ **L'ingénierie sociale** : ensemble des techniques destinées à manipuler (persuasion, intimidation, usurpation d'identité, flatterie ou mise en confiance) une personne ou un groupe de personnes pour obtenir une action ou une information
- ▶ **Objectif** : contourner les protections techniques en obtenant l'aide involontaire d'un individu légitime.

- **Combinaisons de techniques** : Intelligence artificielle, Réseaux sociaux, Données ouvertes, etc.

Evolution of Social and Technological Attacks



Typologie des attaques d'ingénierie sociale

- ▶ **L'interaction humaine**(contact, direct ou indirect avec la victime) : usurpation d'identité, support technique fictif, ingénierie sociale inversée
- ▶ **Scénarios assistés par technologies modernes** : déléguer certaines phases de la manipulation à des systèmes automatisés (IA générative) : deepfakes, exploitation des données publiques ou semi-publiques, chatbots frauduleux, intégration d'espace de discussion professionnelle (Microsoft Teams, Slack ou Discord))

Variantes de phishing

- ▶ **Le spear phishing (hameçonnage ciblé)** : implique une phase préalable de reconnaissance pour collecter des informations spécifiques sur sa cible.
- ▶ **Whaling (chasse à la baleine)** : cible exclusivement les cadres dirigeants ou les profils de haut niveau au sein d'une organisation.
- ▶ **Smishing (hameçonnage par SMS)** : désigne les attaques menées par le biais de messages texte envoyés sur les téléphones mobiles.
- ▶ **Le vishing (voice phishing)** : repose sur des appels téléphoniques ou des messages vocaux enregistrés

Variantes de phishing

- ▶ **Le Quishing (QR phishing)** : consiste à diffuser un code QR piégé qui redirige vers un site frauduleux ou déclenche une action malveillante, comme l'installation d'un logiciel ou l'ouverture d'un formulaire de connexion contrefait.
- ▶ **Phishing dans les réseaux sociaux** : exploitent l'environnement de confiance que les réseaux sociaux créent artificiellement entre utilisateurs connectés
- ▶ **Phishing par empoisonnement de résultats sponsorisés (SEO poisoning ou malvertising)** : exploitation des moteurs de recherche et des publicités sponsorisées

Variantes de phishing

- ▶ **Campagnes multicanaux coordonnées** : s'inspire de tactiques de marketing croisé, en combinant par exemple un e-mail, un SMS, et un appel vocal dans un délai court, afin de crédibiliser une situation factice
- ▶ **Phishing intégré aux applications tierces (WeTransfer, Google Docs, Dropbox, OneDrive)** : création d'un faux document ou d'un formulaire hébergé sur une plateforme légitime, puis envoi d'un lien via e-mail ou messagerie instantanée
- ▶ **Reverse social engineering (Ingénierie sociale inversée)** : met en place un contexte dans lequel la victime se tourne d'elle-même vers l'attaquant, persuadée qu'elle est en présence d'un interlocuteur légitime

Attaques internes et ingénierie sociale

- ▶ **Manipulation involontaire des collaborateurs :**
- ▶ **Insiders malveillants ou frustrés :** un employé mécontent, frustré ou en conflit avec l'entreprise, qui décide de porter atteinte à la sécurité ou à la réputation de son organisation
- ▶ **Périodes critiques :** arrivée et départ des collaborateurs :
- ▶ **Prestataires externes et intérimaires**

Protections contre l'ingénierie sociale

- ▶ **Formation et sensibilisation continues** : privilégier des formats courts, interactifs et contextualisés, diffusion régulière de rappels (via intranet, e-mail, outils collaboratifs)
- ▶ **Contre-mesures techniques essentielles** :
 - Authentification multifacteur (MFA)
 - Analyse comportementale : solutions UEBA (User and Entity Behavior Analytics) pour détecter des écarts significatifs dans les habitudes d'un utilisateur (horaire, emplacement, etc.)
 - Mécanismes de filtrage DNS, ouverture en sandbox des pièces jointes, etc.

1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
3. Attaques sur les applications web
4. Ingénierie sociale et phishing
- 5. Post-Exploitation**
6. Rédaction du rapport de test d'intrusion

- ▶ **Elévation de privilèges (locale ou réseau, temporaire ou permanente)** : outils windows (WinPEAS, Seatbelt ou PowerUp) et Linux (LinPEAS ou GTFOBins)=> commandes mal sécurisées, les droits sudo mal configurés, ou les chemins d'exécution dangereux
- ▶ **Maintenir l'accès : discrétion et persistance** : création d'un utilisateur secondaire, l'ajout d'une tâche planifiée, la création d'un service, ou même la manipulation d'une clé de registre ajout d'une clé SSH, la modification d'un fichier crontab, ou l'utilisation d'un binaire système détourné. Ces actions doivent être **documentées, réversibles, et conformes au périmètre contractuel** .

- ▶ **Mouvement latéral et rebond interne** : Rebondir sur d'autres machines du réseau à partir d'un accès limité
combinaison à une **escalade horizontale** vers des systèmes plus sensibles
- ▶ **BloodHound** : cartographier les relations d'approbation dans un environnement Active Directory.

- ▶ **Outils : CrackMapExec, Impacket, ou Kerbrute**==> permettent de mettre en œuvre des attaques spécifiques : pass-the-hash, pass-the-ticket, kerberoasting, AS-REP roasting, ou SMB relay
- ▶ **Exploitation post-accès : extraction, impact et démonstration** : justifier chaque action, dans une logique de simulation réaliste. Le but est de montrer, pas de profiter (**protéger en révélant, pas exploiter en silence**)

Sommaire

Introduction au Hacking Éthique Présentation de la certification CEH Attaques sur les applications web Ingénierie sociale et phishing

1. Introduction au Hacking Éthique
2. Présentation de la certification CEH
3. Attaques sur les applications web
4. Ingénierie sociale et phishing
5. Post-Exploitation
6. Rédaction du rapport de test d'intrusion

Rédaction du rapport de test d'intrusion

- ▶ **Clore le test proprement, avec méthode et responsabilité** :démontre le sérieux du pentester, sa compréhension des responsabilités qui lui incombent, et son engagement à respecter l'environnement client **gage de confiance**.
- ▶ **Nettoyer, c'est aussi désarmer** :supprimer les fichiers de log locaux des outils utilisés,effacer les sessions SSH créées , retirer les comptes utilisateurs ajoutés...
- ▶ **Notifier formellement que le test est terminé, que toutes les actions ont été arrêtées, et que les accès ont été révoqués**

Rédaction du rapport de test d'intrusion

- ▶ **Le rapport comme livrable principal du test.**
- ▶ **Une structure logique et lisible** Le rapport doit donc être à la fois synthétique pour les décideurs et techniquement précis pour les équipes opérationnelles.
- ▶ **Adapter le contenu au public visé**
- ▶ **Apporter des preuves, mais pas trop**
- ▶ **Proposer des recommandations concrètes et exploitables** : proposer des solutions réalistes, hiérarchisées et compréhensibles. Les recommandations doivent être adaptées au niveau de maturité du client.
- ▶ **Le style, la forme et la responsabilité** : exact, factuel, sourcé et proportionné